

Encuesta Integral de Madurez en Gestión de Riesgos y Cumplimiento PILAR-ENS

Versión 1.0 – Diseñada para responsables de seguridad, TI, continuidad, negocio y alta dirección.

Objetivo: capturar, con un mínimo de dolor y un máximo de honestidad, cómo se aplica realmente el marco ENS apoyado en la metodología PILAR.

1. Datos generales de la organización

1.1 Tipo de organización

- Administración General del Estado
- Administración autonómica
- Administración local
- Universidad / Centro de investigación
- Empresa pública
- Entidad privada con obligaciones ENS (p. ej. prestador de servicios)
- Otra (especificar): ____

1.2 Tamaño aproximado de la organización (número de empleados)

- Menos de 50
- 50–249
- 250–999
- 1.000–4.999
- 5.000 o más

1.3 Ámbito principal de actividad

- Servicios públicos al ciudadano
- Sanidad
- Educación / Ciencia
- Justicia / Seguridad
- Servicios financieros / recaudación
- Infraestructuras / servicios críticos
- Otros (especificar): ____

1.4 Rol de la persona que responde (marque la que mejor encaje, aunque lleve varios sombreros)

- CISO / Responsable de Seguridad de la Información
- Responsable ENS
- Responsable TI / Infraestructuras
- Responsable de Continuidad / BCM
- Responsable de Unidad de Negocio
- Dirección general / gerencia
- Consultor externo
- Otro (especificar): ____

2. Enfoque general de análisis de riesgos (PILAR u otros)

2.1 ¿Utiliza la organización la herramienta PILAR recomendada por el CCN para el análisis de riesgos ENS?

- Sí, como herramienta principal y corporativa
- Sí, pero sólo en algunos sistemas o proyectos
- No, pero utilizamos otra herramienta especializada
- No, utilizamos hojas de cálculo / documentos ofimáticos
- No se realiza un análisis de riesgos estructurado (todavía)

2.2 Frecuencia con la que se actualiza el análisis de riesgos de los sistemas bajo el ENS

- Al menos una vez al año, con carácter sistemático
- Cada 2-3 años o cuando hay cambios relevantes
- Sólo ante proyectos grandes / auditorías / incidentes
- Se realizó una única vez para “cumplir” y no se ha revisado
- No se ha realizado aún un análisis formal de riesgos

2.3 Alcance del análisis de riesgos con relación a sistemas y activos críticos

- Incluye todos los sistemas y activos relevantes cubiertos por el ENS
- Incluye la mayoría, pero hay áreas aún fuera de alcance
- Se limita a uno o dos sistemas “emblemáticos”
- Se centra en la infraestructura técnica, dejando fuera procesos de negocio
- No aplica / no se dispone de análisis sistemático

2.4 Nivel de formalización de la metodología de análisis de riesgos

- Metodología documentada, aprobada y alineada con PILAR/ENS
- Metodología definida, pero no siempre se aplica de forma coherente
- Se siguen pautas básicas, sin metodología formalmente aprobada
- Cada área “se apaña” con su propio método
- No existe metodología definida

3. Modelado de activos, dominios y dependencias

3.1 ¿Cómo se identifican y documentan los activos de la organización en el análisis de riesgos?

- Se utiliza un catálogo estructurado de activos (información, servicios, HW, SW, red, personas, instalaciones)
- Se identifican activos de forma ad hoc en cada proyecto
- Sólo se documentan servidores y aplicaciones principales
- Los activos están implícitos, no hay catálogo formal
- No se identifican activos de forma diferenciada

3.2 En relación con los activos esenciales de información y servicio:

- Están claramente identificados y clasificados según su criticidad
- Están parcialmente identificados, con lagunas conocidas
- Sólo están identificados los “más críticos” de forma informal

- No existe distinción clara entre activos esenciales y de soporte
- No se ha abordado aún esta clasificación

3.3 Uso de dominios de seguridad en el modelado

- Los dominios de seguridad están definidos, documentados y se usan en el análisis (herencia de salvaguardas, etc.)
- Se utilizan dominios de forma aproximada, no siempre coherente
- La idea de dominio es conocida, pero no se aplica en la práctica
- No se trabaja con dominios, se va activo a activo
- No sabe / no contesta

3.4 Dependencias entre activos (incluidas dependencias de negocio)

- Las dependencias están modeladas de forma sistemática (incluyendo nodos OR, redundancias, etc.)
- Se modelan las dependencias principales, pero no todas
- Se describen dependencias de forma narrativa, sin modelado formal
- No hay modelado de dependencias; se asumen de forma implícita
- No sabe / no contesta

3.5 Uso de zonas y fronteras (perimetales, lógicas, físicas, TEMPEST, etc.)

- Las zonas están definidas y se usan como base del análisis y de los controles
- Existen zonas definidas, pero con un uso parcial o irregular
- La segmentación existe técnicamente, pero no se refleja en el análisis de riesgos
- No se gestionan zonas ni fronteras de forma explícita
- No aplica / no se considera relevante

4. Valoración de requisitos de seguridad (Confidencialidad, Integridad, Disponibilidad, etc.)

Para las siguientes preguntas, considere la escala habitual de 0 a 10 para la demanda de seguridad sobre cada dimensión (C, I, D, autenticidad, trazabilidad, privacidad).

4.1 ¿Cómo se determinan los niveles de confidencialidad, integridad y disponibilidad de los activos esenciales?

- A partir de criterios documentados, vinculados a impacto en negocio / servicio al ciudadano
- Mediante consenso entre negocio, TI y seguridad, aunque sin criterios formalizados
- Decisión principalmente técnica, con poca participación de negocio
- Estimaciones históricas copiadas de análisis anteriores
- No se determinan de forma explícita

4.2 Participación de las unidades de negocio en la asignación de niveles 0-10

- Participan de forma activa y sostienen la justificación de los niveles
- Participan puntualmente para activos muy críticos
- Son consultadas de forma superficial

- No participan; los niveles se fijan desde TI / seguridad
- No aplica / no se utilizan niveles cuantitativos

4.3 Coherencia entre la clasificación de información y los niveles definidos en el análisis de riesgos

- Alta: existe alineación y trazabilidad bidireccional
- Media: en general alineados, con algunas discrepancias asumidas
- Baja: hay varias incongruencias conocidas
- No existe sistema formal de clasificación
- No sabe / no contesta

4.4 Tratamiento específico de la privacidad / datos personales

- Se valoran explícitamente como dimensión adicional con criterios definidos
- Se consideran en conjunto con confidencialidad, sin diferenciar matices
- Se tratan sólo cuando hay auditoría de protección de datos
- No se distinguen; se supone que “van incluidos”
- No aplica / no se tratan datos personales

5. Salvaguardas, controles y niveles de madurez (L0-L5)

En esta sección nos adentramos en el reino de los L0 a L5. Respire hondo.

5.1 ¿Existe un catálogo de salvaguardas (medidas técnicas, organizativas, físicas) alineado con ENS / ISO / NIST?

- Sí, corporativo, mantenido y vinculado al análisis de riesgos
- Sí, pero fragmentado por áreas o proyectos
- Se utilizan catálogos de terceros (consultores, proyectos) sin unificar
- Las salvaguardas se definen caso a caso, sin catálogo
- No se dispone de catálogo identificable

5.2 ¿Cómo se valora la madurez de las salvaguardas (L0-L5)?

- Con criterios definidos por nivel, aplicados de forma consistente
- Con criterios generales, dejando margen amplio a la interpretación
- A través de la percepción del responsable, sin criterios explícitos
- Sólo se indica si la salvaguarda “existe” o “no existe”
- No se utiliza un modelo de madurez

5.3 Distinción entre madurez de salvaguardas y madurez de controles / cumplimiento formal

- Se diferencian claramente ambas dimensiones y se miden por separado
- Se diferencian en teoría, pero en la práctica se mezclan
- No se distingue; la madurez se asume igual para todo
- No se mide la madurez, sólo el grado de implantación cualitativa
- No sabe / no contesta

5.4 Nivel medio de madurez percibido de las salvaguardas (estimación global)

- L0-L1: predomina la improvisación, aunque haya héroes

- L2: se reproducen buenas prácticas, pero sin proceso maduro
- L3: procesos definidos y mantenidos con cierta estabilidad
- L4: procesos medidos y controlados de forma regular
- L5: mejora continua basada en métricas y objetivos cuantitativos
- No aplica / desconocido

5.5 Uso del modelo de madurez recomendado por el ENS (guías CCN-STIC)

- Se aplica con cálculo sistemático de índices de madurez ENS
- Se utiliza como referencia conceptual, sin cálculo formal de índices
- Se conoce, pero no se ha aplicado aún
- No se conoce
- No sabe / no contesta

6. Indicadores de recomendación, overkill/underkill y aplicabilidad

6.1 Uso de la “recomendación” de medidas (0–10) generada o sugerida por la herramienta

- Se utiliza como criterio principal de priorización
- Se utiliza como una referencia más, junto con juicio experto
- Se consulta esporádicamente, sin papel relevante en decisiones
- No se utiliza; la recomendación se ignora
- La herramienta utilizada no proporciona esta funcionalidad

6.2 Gestión de medidas consideradas “overkill” (excesivas)

- Se analizan, documentan y, en su caso, se reconducen o justifican
- Se discuten sólo cuando la dirección cuestiona el coste
- Se asumen como mal menor, sin revisar
- No se identifican ni gestionan específicamente
- No sabe / no contesta

6.3 Gestión de medidas consideradas “underkill” (insuficientes frente al riesgo)

- Se prioriza su refuerzo con planes de acción y plazos definidos
- Se registran como riesgos aceptados por la dirección
- Se reconocen, pero no se tratan de forma sistemática
- No se identifican de forma diferenciada
- No sabe / no contesta

6.4 Tratamiento de la aplicabilidad de las medidas ENS

- Se evalúa y documenta para cada medida, con justificación clara de “no aplicable”
- Se evalúa, pero con justificaciones genéricas
- Se admite “no aplicable” de forma laxa para reducir carga de trabajo
- No se evalúa la aplicabilidad; se asume que todo aplica
- No sabe / no contesta

6.5 Existencia de controles ENS “obligatorios” marcados como no aplicables

- Sí, y se dispone de justificación formal revisada por la dirección
- Sí, pero la justificación es principalmente técnica
- No se han marcado controles obligatorios como no aplicables
- No está claro cómo se ha gestionado
- No aplica / no se ha trabajado aún

7. Cuadros de mando, semáforos y comunicación al comité de dirección

7.1 Uso de semáforos (rojo/ámbar/verde) para representar el estado de las medidas y riesgos

- Sí, de forma sistemática en cuadros de mando periódicos
- Sí, pero principalmente en informes puntuales
- Se utilizan descripciones textuales sin semáforos visuales
- No se elaboran informes de estado estructurados
- No sabe / no contesta

7.2 Alcance de los cuadros de mando de seguridad y riesgo

- Cubren riesgos, madurez, cumplimiento ENS y planes de acción
- Cubren principalmente incumplimientos y hallazgos de auditoría
- Se limitan a incidentes y estadísticas de eventos
- No existen cuadros de mando como tales
- No sabe / no contesta

7.3 Frecuencia de presentación al comité de dirección u órgano equivalente

- Mensual
- Trimestral
- Semestral
- Anual
- Sólo cuando hay un incidente o auditoría importante
- No se presenta la información de forma estructurada

7.4 Nivel de comprensión percibido por la alta dirección

- Alto: pueden interpretar indicadores y tomar decisiones informadas
- Medio: comprenden lo esencial, con apoyo de explicaciones
- Bajo: se presenta como formalidad, sin debate sustancial
- Muy bajo: la seguridad se percibe como coste inevitable
- No sabe / no contesta

8. Ciclo de vida, proyectos y continuidad de negocio

8.1 Integración del análisis de riesgos en el ciclo de vida de proyectos y sistemas

- Obligatorio en fases de diseño, implantación y cambios relevantes
- Se realiza principalmente al inicio del proyecto
- Se hace sólo al final, para “regularizar” antes de la puesta en producción

- No se integra de forma sistemática en los proyectos
- No sabe / no contesta

8.2 Uso de fases de proyecto y herencia de madurez (estado actual, objetivo, etc.)

- Se definen fases, se heredan valores y se documenta la evolución
- Se definen fases, pero se trabaja casi siempre sobre la última
- Se trabaja sobre una única foto fija
- No se manejan fases ni evolución temporal
- No sabe / no contesta

8.3 Existencia y actualización de planes de continuidad y de contingencia

- Existen, están alineados con el análisis de riesgos y se prueban periódicamente
- Existen, pero con pruebas parciales o irregulares
- Existen en borrador, pendientes de aprobación o prueba
- No existen planes formales de continuidad / contingencia
- No sabe / no contesta

8.4 Vinculación entre resultados de PILAR y planificación de continuidad / resiliencia

- Alta: se usan riesgos y puntos únicos de fallo para diseñar la continuidad
- Media: se tienen en cuenta algunos riesgos, de forma no estructurada
- Baja: se han diseñado planes sin apoyo real en el análisis de riesgos
- Nula: continuidad y análisis de riesgos discurren por caminos paralelos
- No sabe / no contesta

9. Indicadores, métricas de madurez (IGM) y retorno de la inversión (ROI) en seguridad

9.1 Existencia de un Índice Global de Madurez (IGM) de seguridad o ENS

- Sí, definido y calculado regularmente a nivel corporativo
- Sí, pero calculado sólo para algunos ámbitos o proyectos
- En diseño, aún no operativo
- No, aunque se utilizan indicadores dispersos
- No se dispone de índice ni indicadores significativos

9.2 Componentes que se tienen en cuenta en el IGM (si aplica)

- Madurez de salvaguardas (L0–L5)
- Cumplimiento de medidas ENS
- Grado de implementación de planes de acción
- Resultados de auditorías / revisiones
- Métricas de incidentes y tiempos de respuesta
- Otros (especificar): ____
- No aplica / no se dispone de IGM

9.3 ¿Se calcula o estima el ROI de inversiones en seguridad / ENS?

- Sí, con modelos cuantitativos (reducción esperada de pérdida, etc.)

- Sí, de forma cualitativa (argumentos de riesgo y cumplimiento)
- Se menciona en presentaciones, sin cálculo estructurado
- No, el ROI se da por supuesto
- No sabe / no contesta

9.4 Uso de indicadores adelantados y rezagados (leading/lagging)

- Se utilizan ambos tipos y se revisan periódicamente
- Predominan indicadores rezagados (incidentes, fallos, etc.)
- Predominan indicadores adelantados (controles, formación, etc.)
- No se distingue entre tipos de indicadores
- No sabe / no contesta

9.5 Grado de integración de las métricas de seguridad en la gestión global de riesgos corporativos

- Alta: seguridad es parte del mapa integral de riesgos
- Media: se reporta, pero en un apartado relativamente aislado
- Baja: aparece sólo en anexos técnicos
- Nula: la gestión de riesgos corporativos ignora la seguridad TI
- No sabe / no contesta

10. Cultura, recursos y factores humanos

10.1 Nivel de sensibilización de la plantilla respecto a la seguridad y al ENS

- Alto: programas regulares, campañas y seguimiento de resultados
- Medio: formación esporádica y materiales a disposición
- Bajo: alguna acción aislada en los últimos años
- Muy bajo: se confía en el sentido común
- No sabe / no contesta

10.2 Dotación de recursos humanos dedicados a seguridad / ENS

- Equipo especializado y estable, con roles definidos
- Equipo parcial, combinando funciones de TI y seguridad
- Una o dos personas “hombre orquesta”
- Responsabilidades difusas, sin dedicación clara
- No sabe / no contesta

10.3 Actitud de la organización frente al riesgo (honestidad, aceptación, negación, etc.)

- Realista: se admite el riesgo y se gestionan prioridades
- Prudente: se tiende a sobreproteger, pero se documenta
- Optimista: se confía en que “no nos va a pasar”
- Resignada: “no hay recursos, así que poco se puede hacer”
- Esquizofrénica: discurso oficial muy ambicioso, práctica tímida
- No sabe / no contesta

11. Cierre

11.1 ¿Estaría dispuesto/a su organización a compartir de forma anónima sus indicadores agregados para estudios sectoriales de madurez ENS?

- Sí, sin restricciones
- Sí, bajo acuerdo de confidencialidad
- Tal vez, dependiendo de las condiciones
- No, en ningún caso
- No sabe / no contesta

11.2 Comentarios adicionales, confesiones voluntarias o plegarias tecnológicas

- Campo de texto libre